

Frameworks SSRFmap e XSS Strike

PEDRO JERSEY - 2311220
LUCA VERDADE - 24101167

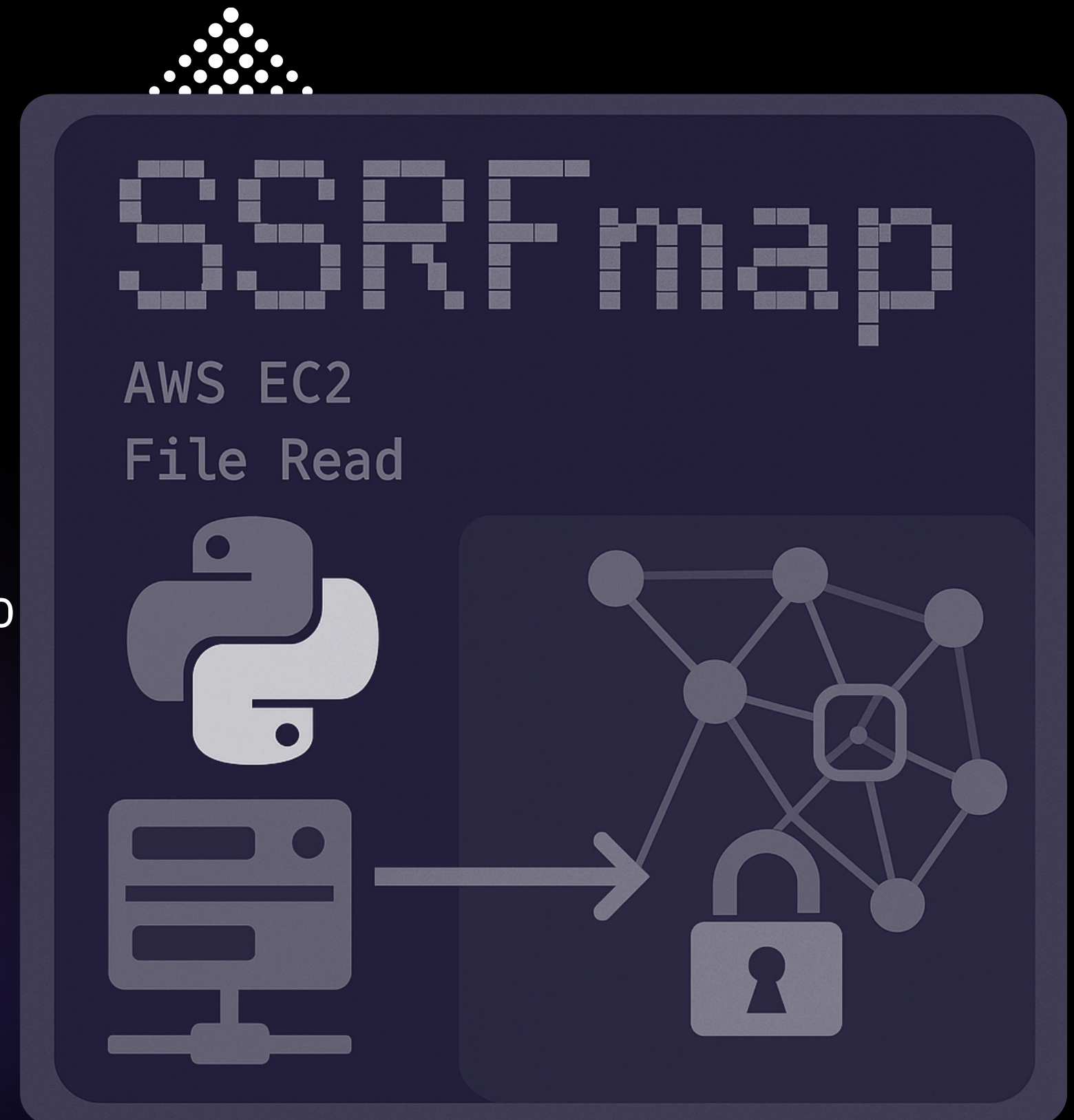
O que são Frameworks de Testes de Segurança?

- Frameworks de segurança automatizam testes para identificar vulnerabilidades em aplicações web.
- Auxiliam na detecção de falhas de entrada, configuração e autenticação.
- Ajudam na integração com pipelines de CI/CD para segurança contínua.



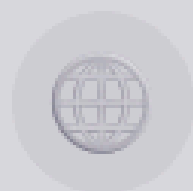
SSRF Map

- Ferramenta de exploração automatizada de Server-Side Request Forgery (SSRF).
- Desenvolvida em Python, foca em automatizar a detecção e exploração desse tipo de vulnerabilidade.



Funcionalidades

- Detecção automática de parâmetros vulneráveis a SSRF.
- Exploração automatizada com payloads pré-definidos.
- Suporte a diferentes protocolos (HTTP, HTTPS, Gopher, FTP, File, etc).
- Bypass de filtros e WAFs.
- Output estruturado em JSON.



Múltiplos Protocolos

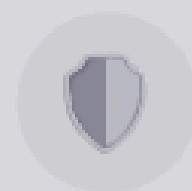
Suporte amplo para diferentes esquemas

HTTP

HTTPS

Gopher

FTP



Bypass de Filtros e WAFs

Técnicas avançadas de evasão

127.0.0.1 → 0x7f000001 → 2130706433

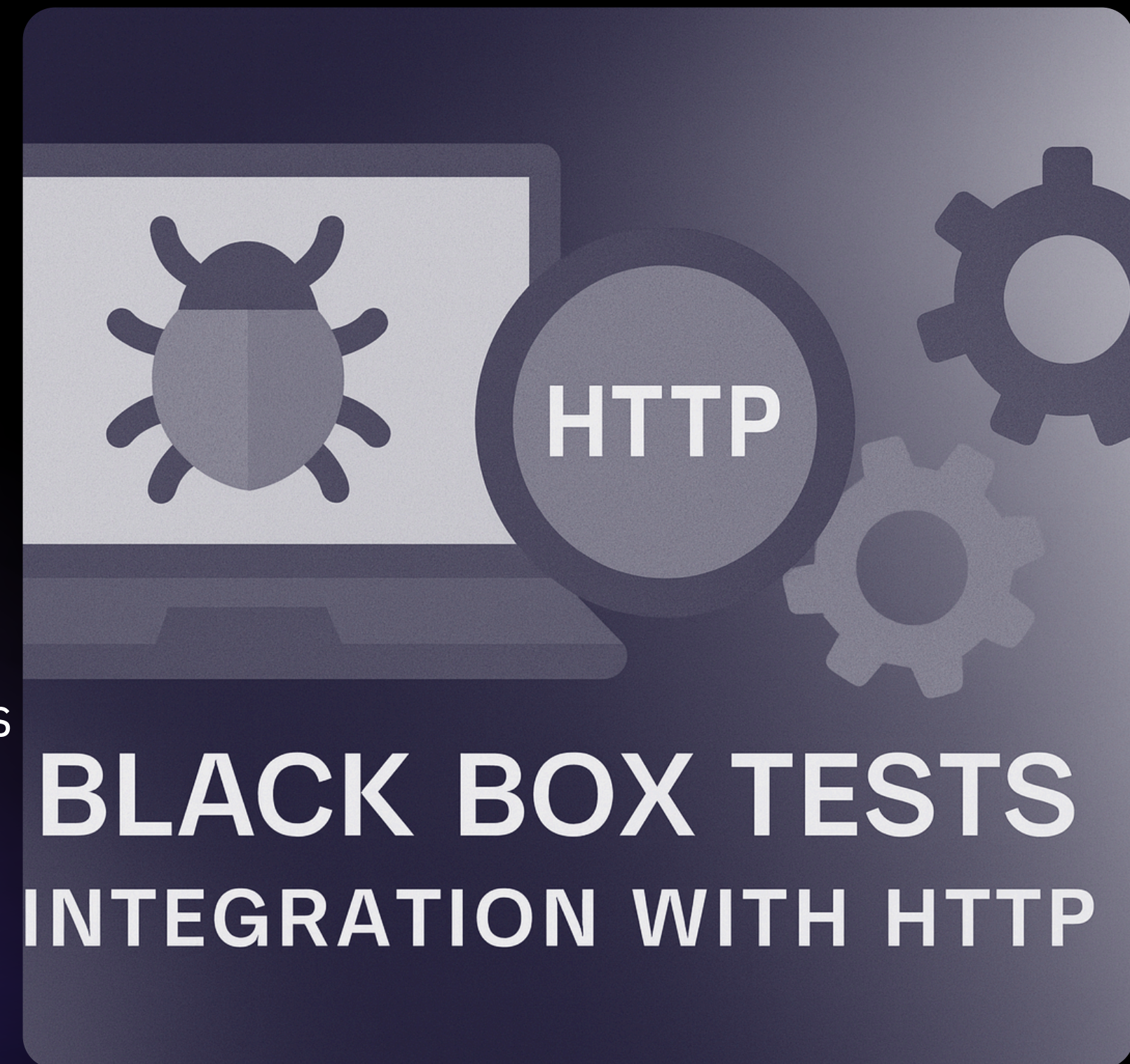
SSRF Map

Tipos de Testes:

- Teste caixa-preta, com base em entradas e respostas HTTP.

Integrações:

- Pode ser usado junto a Burp Suite, ZAP Proxy e pipelines CI.



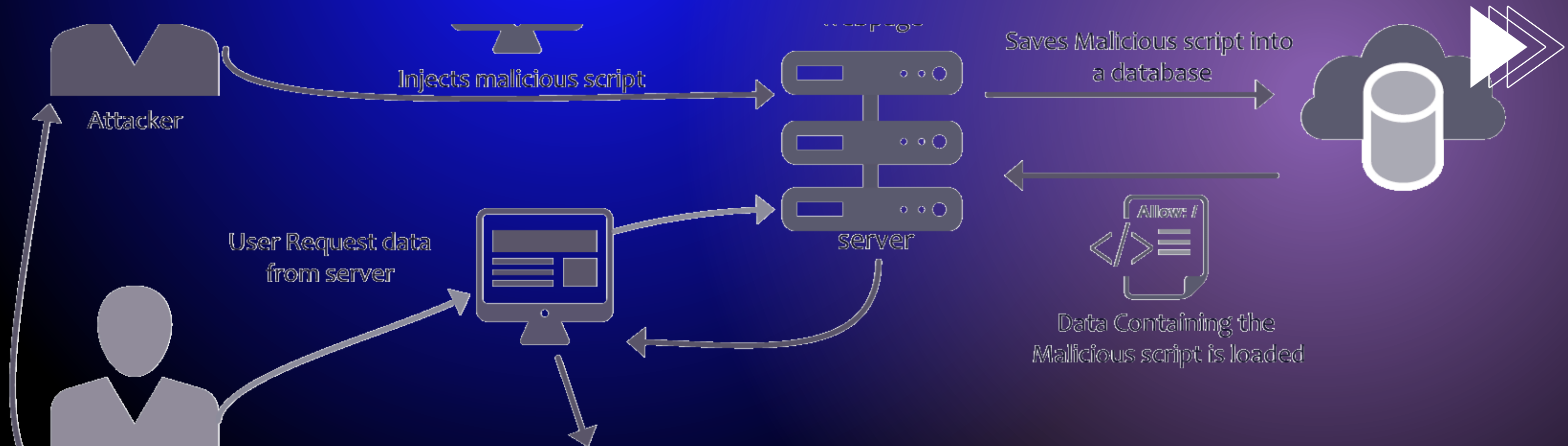
XSS Strike

- Framework automatizado para exploração de Cross-Site Scripting (XSS).
- Usa heurísticas inteligentes e fuzzing para testar entradas vulneráveis em aplicações web.



Funcionalidades

- Motor de fuzzing inteligente com base em contexto HTML e JS.
- Detecção de filtros e evasão automática.
- Execução de payloads personalizados.
- Teste de XSS refletido, armazenado e DOM-based.
- Output detalhado com contexto do parâmetro vulnerável.



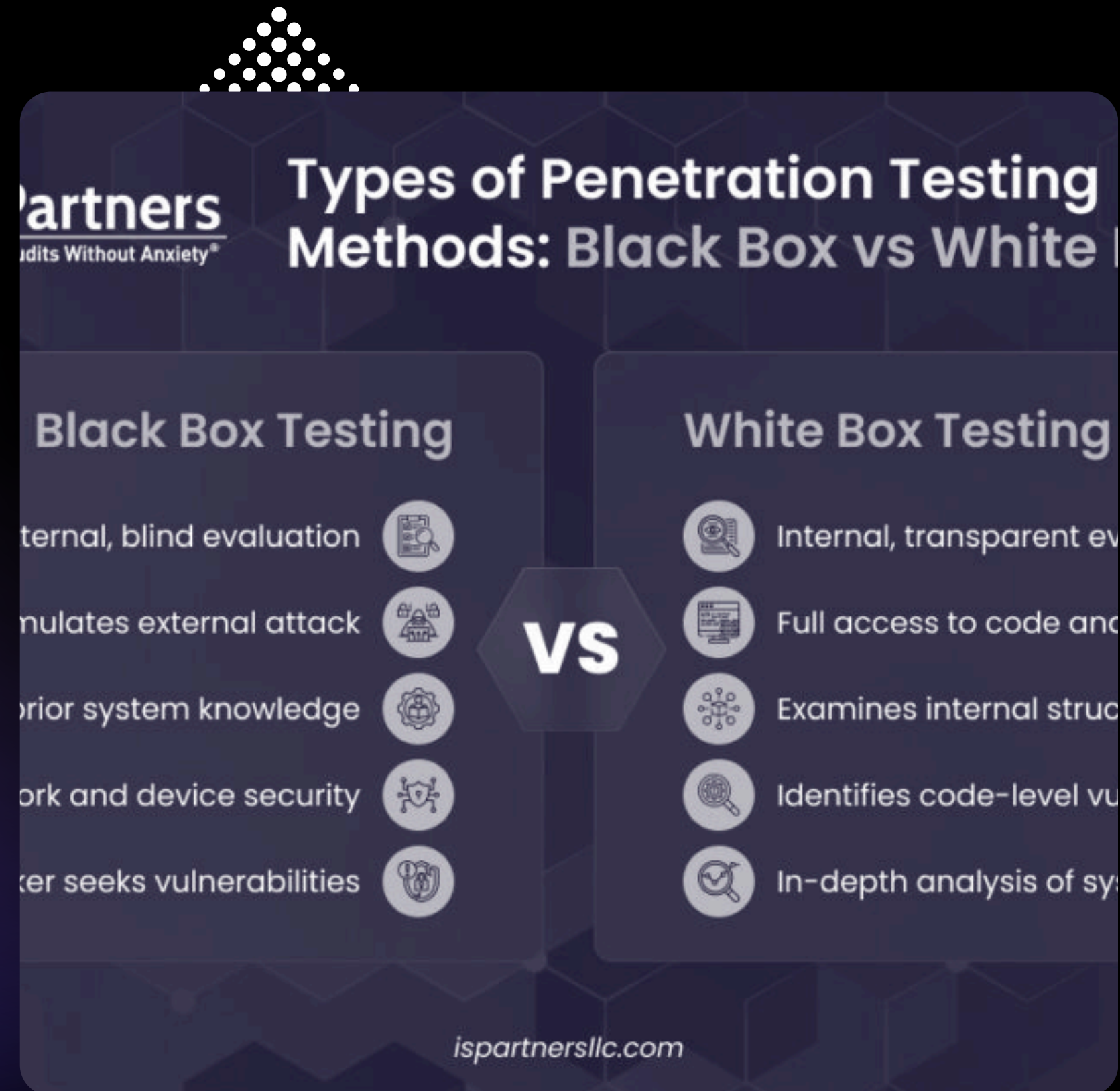
XSS Strike

Tipos de Testes:

- Caixa-preta e parcialmente caixa-branca (pode usar código-fonte em modo verbose).

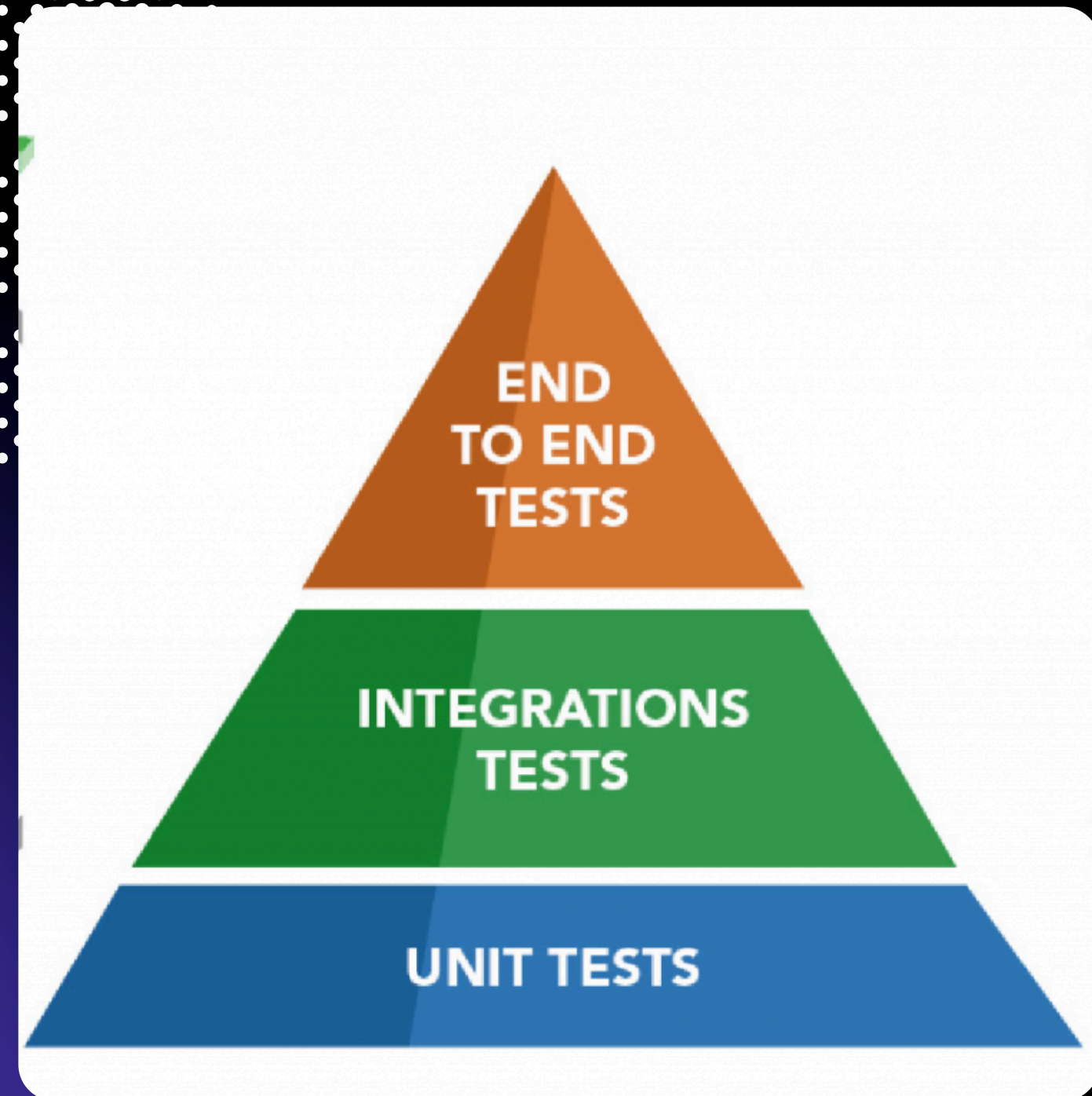
Integrações:

- Compatível com Selenium, Burp Suite, e automações CI/CD.
- Executável via linha de comando em pipelines DevSecOps.



Pirâmide de Testes

- Testes de Unidade (Base): voltados a funções isoladas → não aplicável aqui.
- Testes de Serviço/API (Intermediário): valida endpoints e lógicas → parcialmente aplicável ao SSRFmap.
- Testes de Interface/Segurança (Topo): testes end-to-end e de entrada do usuário → foco principal de XSS Strike e SSRFmap.



01.

Ideal para pentesters e analistas que lidam com backends expostos a requisições externas

SSRF
map

02.

Pode gerar falso-positivos se não configurado corretamente.

01.

Excelente para detecção rápida de vulnerabilidades XSS e integração em pipelines.

02.

Não substitui análise manual em aplicações com JavaScript complexo.

XSS
Strike

Quando Adotar

- Durante auditorias web, pentests e automações de segurança contínuas.
- Evitar uso em ambientes de produção sem permissão explícita.





Quem usa SSRF Map

- Utilizado por equipes de segurança em bug bounties e CTFs.
- Empresas como HackerOne e Bugcrowd relatam uso em análises SSRF automatizadas.

Quem usa XSS Strike

- Ferramenta amplamente usada por pentesters e pesquisadores independentes.
- Mencionada em treinamentos da TryHackMe, Hack The Box, e OWASP Labs.



Obrigado!

